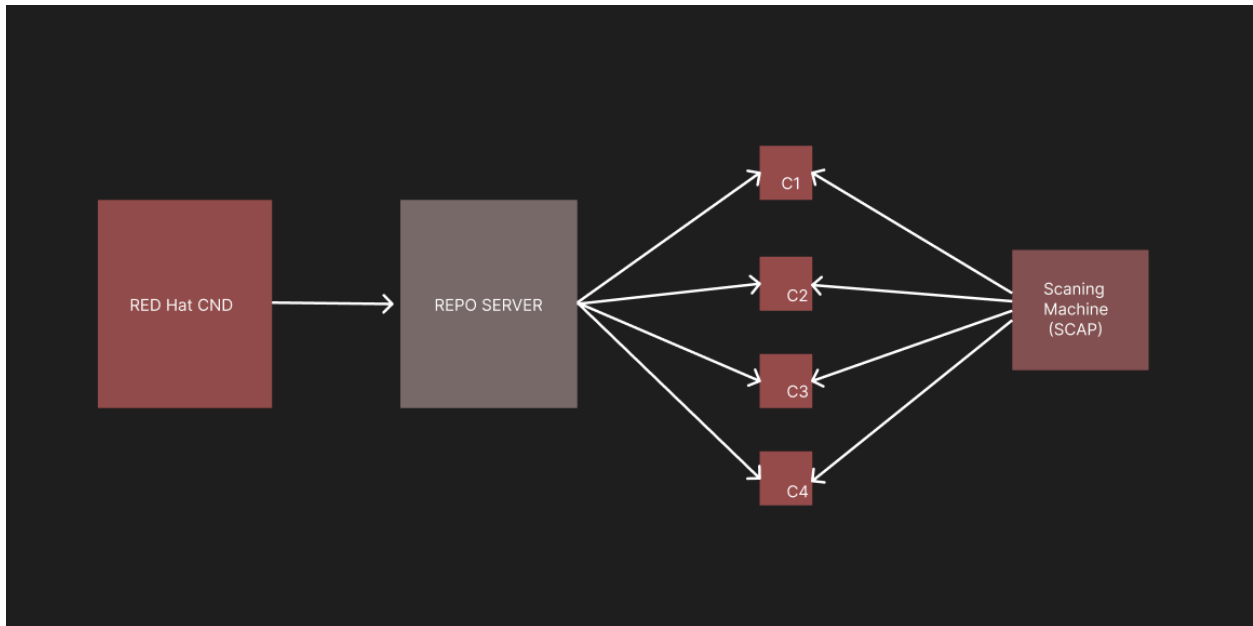


System Patching

Objective: Scan a system, use the local repo server to patch the scanned system.

Prerequisites

- SCAP WORKBENCH
- Scan system(node_1)
- Scanner system + local reposerver
- VMware + vnet



Step 1: scanning target

Download scap-security-guide and openscap-scanner and scap-workbench

Run scap-workbench

And select remote machine and insert user@IP and select DISA STIG profile (CLI)

ssg-rhel9-ds.xml - SCAP Workbench

File Help

Title Guide to the Secure Configuration of Red Hat Enterprise Linux 9

Customization None selected

Profile DISA STIG for Red Hat Enterprise Linux 9 (490) Customize

Target ☐ Local Machine ☒ Remote Machine (over SSH)

User and host root@192.168.233.147 **Port** 22 ☐ user is sudoer root@192.168.233.147:22

Rules Expand all

- ▶ Install AIDE
- ▶ Build and Test AIDE Database
- ▶ Configure AIDE to Verify the Audit Tools
- ▶ Configure Periodic Execution of AIDE
- ▶ Configure Notification of Post-AIDE Scan Details
- ▶ Configure AIDE to Use FIPS 140-2 for Validating Hashes
- ▶ Configure AIDE to Verify Access Control Lists (ACLs)
- ▶ Configure AIDE to Verify Extended Attributes
- ▶ Audit Tools Must Be Group-owned by Root
- ▶ Audit Tools Must Be Owned by Root
- ▶ Audit Tools Must Have a Mode of 0755 or Less Permissive
- ▶ Enable Dracut FIPS Module
- ▶ Enable FIPS Mode
- ▶ FIPS Must Use a Supported Subpolicy
- ▶ Set kernel parameter 'crypto.fips_enabled' to 1
- ▶ Install crypto-policies package
- ▶ Configure BIND to use System Crypto Policy
- ▶ Configure System Cryptography Policy
- ▶ Configure Kerberos to use System Crypto Policy
- ▶ Configure Libreswan to use System Crypto Policy

0% (0 results, 490 rules selected)

Generate remediation role ☐ Dry run ☐ Fetch remote resources ☐ Remediate **Scan**

Save in .html

Guide to the Secure Configuration of Red Hat Enterprise Linux 9

with profile **DISA STIG for Red Hat Enterprise Linux 9**

— This profile contains configuration checks that align to the DISA STIG for Red Hat Enterprise Linux 9 V2R4.

In addition to being applicable to Red Hat Enterprise Linux 9, this configuration baseline is applicable to the operating system tier of Red Hat technologies that are based on Red Hat Enterprise Linux 9, such as:

- Red Hat Enterprise Linux Server
- Red Hat Enterprise Linux Workstation and Desktop
- Red Hat Enterprise Linux for HPC
- Red Hat Storage
- Red Hat Containers with a Red Hat Enterprise Linux 9 image

The SCAP Security Guide Project

<https://www.open-scap.org/security-policies/scap-security-guide>

This guide presents a catalog of security-relevant configuration settings for Red Hat Enterprise Linux 9. It is a rendering of content structured in the eXtensible Configuration Checklist Description Format (XCCDF) in order to support security automation. The SCAP content is available in the `scap-security-guide` package which is developed at <https://www.open-scap.org/security-policies/scap-security-guide>.

Providing system administrators with such guidance informs them how to securely configure systems under their control in a variety of network roles. Policy makers and baseline creators can use this catalog of settings, with its associated references to higher-level security control catalogs, in order to assist them in security baseline creation. This guide is a *catalog*, not a *checklist*, and satisfaction of every item is not likely to be possible or sensible in many operational scenarios. However, the XCCDF format enables granular selection and adjustment of settings, and their association with OVAL and OCIL content provides an automated checking capability. Transformations of this document, and its associated automated checking content, are capable of providing baselines that meet a diverse set of policy objectives. Some example XCCDF *Profiles*, which are selections of items that form checklists and can be used as baselines, are available with this guide. They can be processed, in an automated fashion, with tools that support the Security Content Automation Protocol (SCAP). The DISA STIG, which provides required settings for US Department of Defense systems, is one example of a baseline created from this guidance.

Do not attempt to implement any of the settings in this guide without first testing them in a non-operational environment. The creators of this guidance assume no responsibility

Complete Report is present [here](#)

Step 2: Filter

Go through the report filter out fail tests and then analyse them and re-filter according to requirements

EX: 1) In report ssh as root will be tagged as exploit but while accessing remote system we would required root

So filter according to needs

Step 3: Find Remedies

There are multiple ways to get remedies for exploits some are listed below

- Red hat Docs([security Hardening](#), [Scap](#))
- Generating Bash script via scap-workbench
- Using separate Bash, ansible script for individual fix
- Description under the details of an exploit

Step 4: Apply the Remedies

Best Practices before Patching

- Backup whole data
- Create screenshots if machine is VM
- Assess risk/impact on system
- Review dependencies

Activity Report

After the initial scan there were

- 268 fail tests
- 175 passed
- 19 low sensitivity
- 234 medium sensitivity
- 12 High sensitivity

Compliance and Scoring

The target system did not satisfy the conditions of 268 rules! Please review rule results and consider applying remediation.

Rule results



Severity of failed rules



Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	48.231464	100.000000	48.23%

[Status of Report before any fix](#)